O governo brasileiro está hospedando cassino para o Google

Sou Juan Matheus Rebello Santos, o hacker cego. Pesquisador independente, sem vínculo com governo nem com empresa de segurança. Passei o dia 30 de outubro de 2026 varrendo 65.590 endereços públicos do país com um leitor de tela e um terminal. Encontrei 304 servindo página de aposta para o robô do Google — em prefeituras, câmaras, um instituto federal, oito universidades e uma secretaria estadual de Saúde. O governo sabe desde 2023.

Por Juan Matheus Rebello Santos · o hacker cego · 30 de outubro de 2026

Olá, pessoal

Meu nome é Juan Matheus Rebello Santos. Na internet, muita gente me conhece como o hacker cego. Sou pesquisador independente de segurança cibernética: não trabalho para órgão público, não presto serviço para empresa de segurança, não recebo verba de ninguém para fazer esta pesquisa. Faço no meu computador, com conexão residencial, um leitor de tela, um terminal e paciência.

A cegueira não é detalhe biográfico nesta história. É método.

Quem ataca servidor público contando com cloaking aposta que ninguém vai olhar o que o robô recebe. A página que o visitante vê é limpa; a sujeira fica escondida no HTML servido ao Googlebot. Quem enxerga a tela vê o site funcionando. Eu não enxergo a tela — eu leio o código. E o código que chega para mim é o mesmo que chega para o robô, se eu pedir com o User-Agent certo.

Foi assim que eu achei o primeiro caso.

No começo de outubro, eu acompanhava as reportagens sobre bets sendo derrubadas no Brasil. Na mesma semana, buscando outra coisa, encontrei um resultado com domínio `.gov.br` e título de loja de aplicativos no Google. A página que abriu para mim não tinha o portal da prefeitura: tinha reprodução de caça-níquel.

Passei o resto do mês investigando. Este texto é o resultado — e vem com planilha, script, relatório e PDF abertos, para que qualquer pessoa refaça a conta. Não peço que acreditem em mim. Peço que verifiquem.

O que eu encontrei

O primeiro caso que confirmei foi o Instituto Nacional de Pesquisas da Amazônia.

`www.inpa.gov.br`. No navegador comum, o portal normal do instituto. Com User-Agent de Googlebot, 62 KB de uma ficha falsa de aplicativo chamada *"jogo do macaco slots for Android - Search on Google Play"*. Não é o site do INPA: é uma página de aposta vestida com o domínio do INPA.

No mesmo servidor — `200.17.53.5` — o `acta.inpa.gov.br` (repositório científico Acta Amazônica) e o `webmail.inpa.gov.br` fazem a mesma coisa. Três de três. O apex `inpa.gov.br` e o `pg.inpa.gov.br` estão limpos — o que mostra como a limpeza é feita: vhost por vhost, sem ninguém olhar o conjunto.

Do INPA eu fui para o resto do país.

Encontrei prefeituras no Piauí com **583, 670, 699, 761 links** de aposta na página inicial. O portal da transparência de Serra, no Espírito Santo, com 63 links injetados. A página de **pagamentos** da Universidade Federal do Piauí servindo spam. A página de **pré-matrícula** da UNIFESP. Três sites de congressos do IAG, na USP, todos de 2019, todos em HTTP puro, todos com o mesmo bloco de links.

E um caso que não é invasão nenhuma: `hackathon.curitiba.pr.gov.br`, a página do hackathon da Prefeitura de Curitiba, hoje serve 238 KB de um site de gambling indonésio — para qualquer visitante, sem disfarce. Alguém abandonou o subdomínio e outra pessoa ocupou.

Como o golpe funciona

A parte técnica é mais elegante do que parece, e é por isso que sobrevive tanto tempo.

O servidor comprometido olha o `User-Agent` de quem chega. São três respostas para a mesma URL:

Se quem chega é o Googlebot, ele entrega uma página falsa de loja de aplicativos — "Apps no Google Play", nota 4,7, "481.772 avaliações", botão "Instalar". O texto abaixo do botão, que só o robô lê, é copy de casa de aposta: "giros grátis por depósito com criptomoedas", "plataforma de apostas esportivas online confiável". O `canonical` aponta para a própria URL `.gov.br`, então o Google indexa aquilo como página oficial do governo.

Se quem chega é um celular vindo do Google (com `Referer` de busca), ele entrega 1 KB: um spinner, "Redirecionando em 1s..." e um `window.location.href` para fora. O destino tem

parâmetro de afiliado — `?ch=137149` num dos casos — e termina num gateway que esconde o cassino real. No portal de Cuiabá, o caminho passa por um `bit.ly` que responde 301 para uma casa de aposta com `campaign_id` de campanha.

Se quem chega é um Chrome comum ou o navegador do WhatsApp, ele entrega um desafio do Cloudflare de 59 KB. Nada de conteúdo. Basta trocar o `User-Agent` para o do Googlebot e a página de aposta aparece.

Isso tem uma consequência prática importante: **quem testa com um `curl` só, com qualquer User-Agent, vê 404 e conclui que está tudo limpo**. Foi por isso que o problema durou tanto. As ferramentas de monitoramento comuns não fazem a pergunta certa.

E há uma variante pior: em `autodiscover.acreuna.go.gov.br`, a página não só indexa aposta — ela **distribui APK**. O arquivo fica em `s3.cdnppp889.com/.../apk` e a página lista dezenas de domínios de cassino. É o que a Recomendação 17/2026 do CTIR chama de "vetor ativo para distribuição de malwares". Deixou de ser teoria.

Como eu fiz

Não existe lista pública de todos os subdomínios `.gov.br`. O Registro `.br` não publica o zone file, e os logs de Certificate Transparency são um retrato histórico: dos 30.766 nomes que extraí do `crt.sh`, cerca de 70% nem resolvem mais em DNS.

Então montei a base por baixo:

1. **Certificate Transparency** — 30.766 nomes de subdomínios com certificado emitido.
2. **Enumeração municipal** — os 5.571 municípios do IBGE, e para cada um 14 padrões de host (`apex`, `www`, `portal`, `prefeitura`, `cpanel`, `autodiscover`, `mail`, `webmail`, `transparencia`, `saude`, `educacao`, `camara`, `cm`, `semed`), com e sem hífen. Resolvi DNS de tudo: 25.823 hosts vivos.
3. **Universidades e institutos federais** — 44 domínios de universidades, mais todo o `.edu.br`: 16.663 hosts.

Total: **65.590 hosts distintos**, um GET na home de cada um, com User-Agent de Googlebot, extraindo âncoras, `iframe`, `script` e `form action` que casassem com 130 termos (aposta, cassino, bet, tigrinho, torrent, baixar jogos, apk, marcas conhecidas) e com termos em tailandês e indonésio.

Depois resolvi o DNS de tudo de novo, agora para agrupar por IP. Foi o passo que mudou a pesquisa: descobri que o comprometimento não é por site, é por **servidor de hospedagem**

compartilhada.

Tudo foi feito em terminal, com leitor de tela. O script, os resultados e o relatório estão no repositório público. Qualquer um pode rodar de novo — inclusive quem não vê a tela, porque a saída é texto.

O tamanho do problema

304 hosts confirmados, em 15 estados mais o Distrito Federal.

- **Piauí** — 203
- **Goiás** — 16
- **São Paulo** — 12
- **Mato Grosso do Sul** — 10
- **Pernambuco** — 8
- **Alagoas** — 8
- **Paraná** — 6
- **Minas Gerais** — 3
- **Rio Grande do Sul** — 3
- **INPA (Amazonas)** — 3
- **Rio Grande do Norte** — 2
- **Santa Catarina** — 2
- **Espírito Santo, Ceará, Maranhão** — 1 cada
- **Universidades** — 25 hosts em 8 instituições

E zero em 15 estados, incluindo Bahia (2.169 hosts testados), Paraíba (1.059), Ceará (780), Mato Grosso (838) e toda a região Norte.

O número que resume a distorção: **São Paulo testou 3.264 hosts e teve 12 infecções. Pernambuco testou 969 e teve as mesmas 12.** Não é população, não é região, não é orçamento de TI. É quantos domínios estão naquele servidor comprometido.

O Piauí não é um caso, é um servidor

O endereço `107.190.141.98` responde por **216 domínios municipais do Piauí**. Duzentos e dezesseis. Praticamente um estado inteiro numa máquina só.

Desses, 203 estão infectados. E não é só o site da prefeitura: o `cpanel`, o `webmail`, o `webdisk`, o `mail` e o `autodiscover` de cada uma respondem com o mesmo kit. Ou seja — **o servidor de e-mail da prefeitura serve página de cassino ao Googlebot**. O serviço que recebe a correspondência oficial do município.

O mesmo desenho em Goiás, no `31.220.75.95`: 18 hosts, e 10 de 10 vhosts de Acreúna, Alexânia, Simolândia, Terezópolis e Camaravalparaíso infectados. Em Mato Grosso do Sul, no `45.178.224.153`: Deodápolis, Jateí, Selvíria, Coronel Sapucaia, Paranhos e Dois Irmãos do Buriti. Na Paraíba e em Alagoas, no `168.0.52.120`: Salgadinho, Taquaritinga do Norte, Lagoa dos Gatos, Rio Formoso e Flexeiras.

Quatro clusters de hospedagem explicam a maior parte dos 304.

O portal da transparência é o alvo preferido

Um padrão que eu não esperava: **16 portais da transparência** comprometidos, em cinco estados — São Paulo (8), Alagoas (4), Minas Gerais (2), Rio Grande do Sul (1) e Espírito Santo (1).

E não estão no mesmo servidor. Os IPs são todos diferentes: `45.7.171.191`, `72.60.245.110`, `107.152.33.207`, `67.205.166.122`, `138.122.72.9`, `177.53.173.44`.

Isso muda a hipótese. Se não é a hospedagem, é o **software**: provavelmente o mesmo produto de portal da transparência, licenciado para dezenas de prefeituras, com a mesma vulnerabilidade não corrigida. Seria comprometimento de fornecedor — e explica por que aparece em cinco estados ao mesmo tempo.

Seria irresponsabilidade minha nomear a empresa sem assinatura técnica. Não tenho. O que tenho é o padrão, e ele está no relatório para quem quiser continuar.

As universidades rodam WordPress

Aqui eu errei no meio do caminho, e vou contar.

Olhei os cabeçalhos dos alvos: Apache 2.2.22 de 2012 no INPA, LiteSpeed com PHP 7.3 no Impar-MG, PHP 7.4 em Juquitiba. Concluí que o CMS não era o fator comum. Estava errado — eu tinha olhado o servidor web, não o CMS.

Quando pedi `/wp-login.php` a cada host confirmado, o resultado foi outro: **23 dos 25 hosts universitários respondem com a tela do WordPress**. UFRGS (6), UFPI (7), USP (3), UFPB (3), UNIFESP (2), UnB (1), UFCSPA (1), IFC (1).

Isso muda a recomendação. Em WordPress, apagar a página injetada não resolve nada: o vetor está em plugin ou tema desatualizado, ou em credencial de administrador vazada. Sem atualizar o que está instalado e trocar as senhas, o kit volta.

E há prova material do vetor. Em `transparencia.saotome.rn.gov.br`, um dos links injetados aponta para:

```
/wp-content/uploads/2026/09/transparencia-saotome-slot-thailand.jpg
```

O arquivo existe. 990 KB, JPEG, `Last-Modified: 30 de setembro de 2026, 05:35 GMT`. O invasor subiu uma imagem de 1 MB para a biblioteca de mídia do WordPress e batizou com o nome do próprio golpe — "slot-thailand". Foi **22 dias depois** da Recomendação 17/2026 do CTIR.

O caso da USP merece um parágrafo. Não é o portal da universidade. São três sites de congressos do IAG — `allam2019`, `firstlight`, `spanet` — de 2019, todos em HTTP puro, sem TLS. Ninguém desligou. Sete anos depois, são doorways com o selo `usp.br`.

O governo sabia. Duas vezes.

ALERTA 10/2023, do CTIR Gov: "foi identificado aumento significativo nos casos de abusos de sítio caracterizado por *Open Redirect*", com usuários "redirecionados para páginas incompatíveis, incluindo sites de apostas, de cassinos e de propagação de *malware*".

RECOMENDAÇÃO 17/2026, publicada em 8 de setembro de 2026: descreve exatamente a campanha que encontrei. "Injeção de rotas dinâmicas e módulos maliciosos (técnica de Cloaking)". O servidor comprometido "intercepta requisições de robôs de busca (como o Googlebot) e injeta em tempo real centenas de links apontando para casas de apostas". Recomenda reinstalar a aplicação a partir do Git, rotacionar todas as credenciais, recriar chaves SSH, montar `/tmp` com `noexec`, restringir compilador em produção, ligar SELinux/AppArmor, instalar FIM.

É um documento tecnicamente correto. Também é uma **recomendação**: o CTIR orienta, o órgão vítima executa. Não existe mecanismo que obrigue um município a provar que reinstalou o servidor depois de notificado.

Sete semanas depois da recomendação, os servidores que testei continuam no ar.

Por que isso nunca é resolvido

O alerta chega em quem não tem time. A maior parte dos casos está em prefeituras pequenas. Servidor mantido por uma ou duas pessoas, CMS de terceiro, plugin desatualizado, hospedagem compartilhada. O checklist da Recomendação 17/2026 pressupõe maturidade que o órgão não tem.

Reinstalar dói mais do que deixar no ar. A recomendação é a certa e é caríssima: reinstalar a aplicação, rotacionar credenciais, refazer chaves. Enquanto isso, o site "está funcionando" — o cidadão não vê nada, porque o cloaking esconde a sujeira.

O sintoma vive no Google, não no servidor. A vítima não recebe reclamação do cidadão. Recebe zero reclamações. Quem vê o problema é o pesquisador, que manda e-mail para `ctir@ctir.gov.br` e espera. Não há painel público, não há lista de órgãos notificados, não há prazo, não há multa.

O SEO premia o domínio do governo. Enquanto o Google tratar `.gov.br` como sinal forte de confiança, injetar página em servidor público vale mais que registrar domínio novo.

O dinheiro está do outro lado. `ch=137149`, `campaign_id=504657721161678848`: cada redirecionamento é comissão de afiliado. Não é hacktivismo, é receita recorrente. Por isso a página volta depois da limpeza.

O que eu errei

Publicar número sem mostrar onde errei é fazer metade do trabalho. Três falsos positivos apareceram no caminho e foram descartados antes de virar manchete:

1. `internetbanking.caixa.gov.br` — o `/apps/` faz 301 legítimo para a ficha real do app Caixa na Play Store. Meu script seguiu o redirect, baixou 1,1 MB da Google Play e marcou o banco como infectado. Corrigi o cliente HTTP para não seguir 3xx.
2. Cinco prefeituras (`altolonga.pi`, `cachoeirinha.pe`, `calcado.pe`, `guarabira.pb`, `picui.pb`) — "alfa**bet**ização" casando com "bet". Corrigi com fronteira de palavra.
3. `savannah.c3sl.ufpr.br` — espelho de software com projetos `crack-attack`, `pypoker`, `qbittorrent`. Meu regex leu "crack" e "poker" como cassino. Corrigi com exclusão para `Index of /`.

E três ressalvas que precisam ir junto com o número:

- **74% dos nomes do Certificate Transparency não resolvem mais.** O denominador honesto é "infectados / hosts que responderam", não "infectados / nomes da lista".
- **Quatro casos da Bahia ficaram abaixo do limiar** (4 a 7 links) e estão listados como prováveis, não confirmados. Preferi subcontar.
- **O total é uma foto de 30/10/2026**, não um censo. O número real é maior.

O que precisa acontecer

Se você é o órgão: a Recomendação 17/2026 é o roteiro. Na prática, nesta ordem: bloqueie as rotas `/apps/`, `/games/`, `/store/`, `/bonusesr/`, `/wp-form/`, `/app.php/`; reinstale a aplicação a partir do Git, não do backup; rotacione credenciais e chaves SSH; procure tags com `luckydom`, `luckspin`, `pegobet`, `1xbet`; peça remoção no Google Search Console; notifique o CTIR.

Se você é usuário: desconfie de resultado `.gov.br` com título de loja de aplicativos, "download torrent" ou nome de bet. Página de governo não pede para instalar APK. Se for redirecionado para cassino a partir de site do governo, não é o governo vendendo aposta: é o servidor dele trabalhando para outra pessoa.

Se você é pesquisador: não publique o passo a passo do vetor de entrada. Publique o IOC, notifique o CTIR e o CERT.br, dê prazo. O problema não é falta de vulnerabilidade conhecida; é falta de alguém com obrigação de consertar.

Indicadores

Servidores que hospedam os clusters:

- `107.190.141.98` — 216 hosts do Piauí, 203 infectados
- `31.220.75.95` — 18 hosts de Goiás, 10 de 10 vhosts infectados
- `45.178.224.153` — 10 hosts do Mato Grosso do Sul
- `45.7.171.191` — 12 portais da transparência de SP
- `168.0.52.120` — 18 hosts em PE/AL
- `177.70.23.182` — 8 hosts na Bahia
- `200.17.53.5` — INPA
- `200.19.215.60` — Secretaria de Saúde de SC

Famílias de rota: `/apps/`, `/games/`, `/store/`, `/bonusesr/`, `/casinoet/`, `/onlinets/`, `/slotwins/`, `/betplays/`, `/wplog/`, `/slotclub/`, `/jackgame/`, `/prizebet/`, `/dps/`, `/amzs/`.

Arquivo que data a intrusão:
`transparencia.saotome.rn.gov.br/wp-content/uploads/2026/09/transparencia-saotome-slot-thailand.jpg` — 990 KB, 30/09/2026 05:35 GMT.

Rede de afiliados: `eu9nq1fn6.com?ch=137149` → `j7y2gh5.com`; `bit.ly/blazebrvip` → `blazebr1.com?campaign_id=504657721161678848`; SDK `upload.music4ever.me/sdk/7f231a59da086241.js`.

Metodologia e ética

Requisições GET únicas, sem seguir redirect, 0,35 a 0,9 s entre requisições, User-Agent identificável com contato no header `From`. Nenhuma tentativa de login, nenhum payload, nenhuma força bruta de caminho. Nenhum dado de cidadão foi acessado. Só URLs públicas e indexadas.

O que está documentado é **execução de código no servidor para manipular busca e redirecionar tráfego**. Não há, até aqui, evidência pública de exfiltração de base de dados nesses episódios — o GSI afirma que o CTIR não recebeu notificação de vazamento. Mas execução de código é execução de código: quem planta rota dinâmica e backdoor com persistência em Linux pode, amanhã, plantar outra coisa.

Nenhum dos órgãos citados foi contatado antes desta publicação. Os nomes estão no texto para que a notificação seja pública e verificável.

Todo o material está publicado: script, planilha, relatório e PDF, para auditoria independente. Quem quiser refazer, o caminho está aberto — e a saída é texto, não imagem. Isso importa: eu não precisaria ver a tela para chegar aos mesmos 304.

Se você achar mais, achei menos do que devia.

Juan Matheus Rebello Santos — o hacker cego